Welcome to Session on:

SHIFTING THE BALANCE

SECURE-BY-DESIGN STRATEGIES IN PUBLIC SECTOR IT PROCUREMENT



Thilak Pathirage
Chairman- SLCERT

Who Am I?



- **Thilak Pathirage**

  Mr. Thilak Pathirage is a distinguished leader with over 40 years of experience in IT governance, information security, and cybersecurity across the banking and financial services sector, both in Sri Lanka and internationally. He has extensive expertise in governing information and cybersecurity risks, with a strong track record of enhancing organizational resilience and aligning security strategies with business objectives.

- He has held senior leadership roles in Information Systems Audit, Information & Cybersecurity at Seylan Bank, where he was instrumental in advancing the bank's cybersecurity posture and embedding risk governance into core operations. He currently serves as the Chairman of Sri Lanka CERT, the national center for cybersecurity.

- Mr. Pathirage holds a Master of Business Administration (MBA) from the Postgraduate Institute of Management (PIM) and a Bachelor of Commerce (Special) Degree from the University of Sri Jayewardenepura. He is a Fellow of the Institute of Bankers of Sri Lanka and holds multiple internationally recognized certifications in IT governance and cybersecurity.

- As a visionary in his field, Mr. Pathirage continues to play a pivotal role in shaping secure, resilient, and compliant digital ecosystems. He is currently pursuing his PhD research on **"Earning Digital Trust in the Public Sector as a Foundational Requirement of Sri Lanka's Digital Transformation Journey"**, further contributing to the advancement of IT governance and cybersecurity in the country.

Presentation Outline

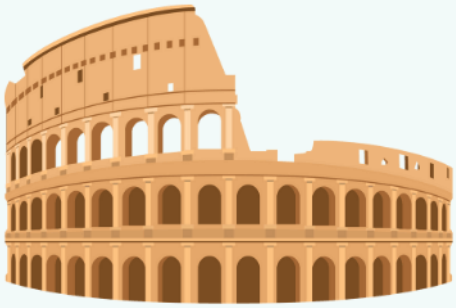
- **Digital Trust & Secure by Design – The Big Picture**
  - Digital Trust as Value Co-Creation
  - Risks & Threats undermining Digital Trust
- **Current Procurement Challenges**
  - Weaknesses in Public Sector IT Procurement
  - Risks in Current Procurement Practices
- **Secure by Design Concepts**
  - Principles of Secure by Design (CISA Framework: shifting responsibility from end-us
  - Integration of Security into Procurement Lifecycle
- **Government Procurement Transformation**
  - Changing Rules of Procurement
  - Strategies for Procurement Staff
- **Global Lessons & Best Practices**
  - International Standards & Frameworks
  - Case Studies of Procurement Failures
- **Practical Framework for Secure Procurement-** Proposed Secure-by-Procurement Model
  - Implementation Roadmap

NATIONAL

Learning Outcomes

By the end of this session, participants will be able to:

- **Understand the importance of digital trust** as a foundation for value co-creation in government digital transformation.
- **Recognize risks and threats** that undermine digital trust,
- **Identify weaknesses in current procurement practices** and the implications for cybersecurity, resilience, and governance.
- **Explain the concept and principles of Secure by Design** (based on CISA's framework) and how it shifts responsibility
- **Explore strategies to integrate security across the procurement lifecycle**,.
- **Examine global lessons, case studies, and international standards** to understand best practices in secure government procurement.
- **Evaluate the proposed Secure-by-Procurement model and roadmap** for transforming procurement rules, processes, and staff competencies.
- **Apply practical tools and strategies** to strengthen procurement staff capacity and embed secure-by-design principles in government procurement.



Rome was not Built in a Day

……means significant or complex things take a **long time and considerable effort** to achieve, emphasizing the need for patience and persistence in any worthwhile endeavor

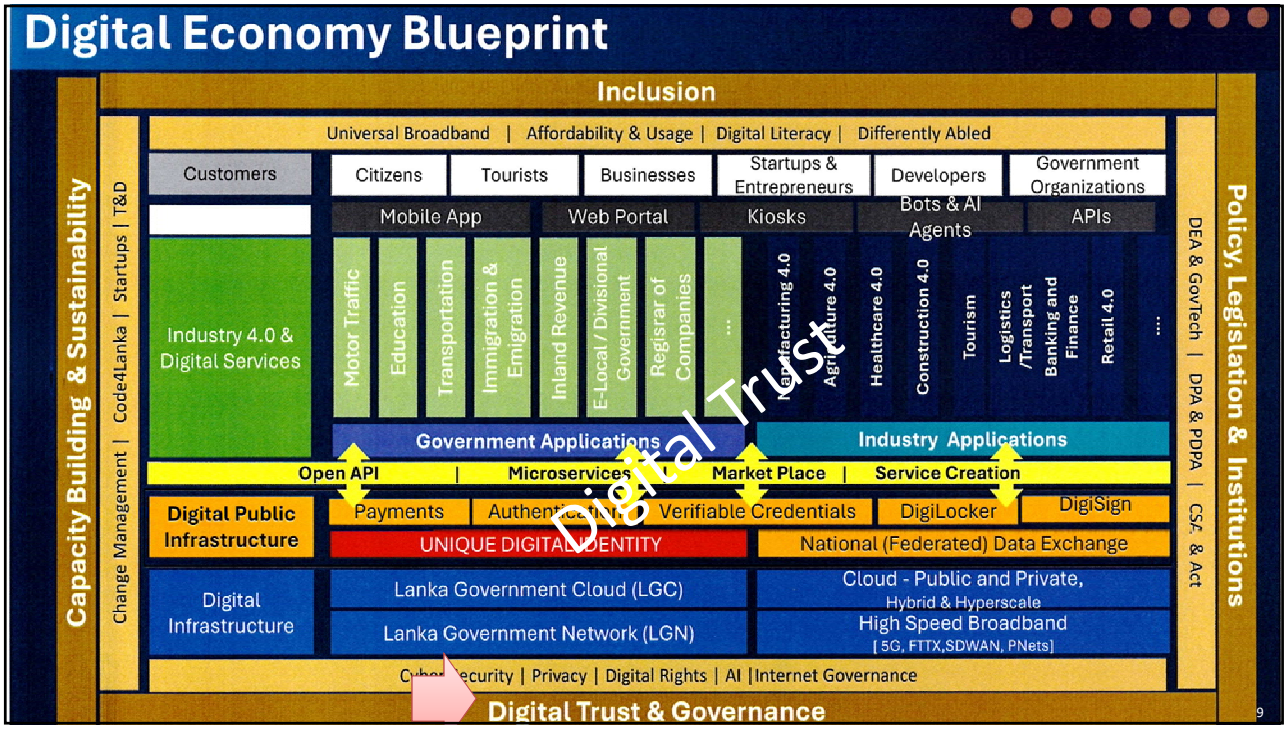
Big Picture

Digital Trust

- Digital Trust can be considered a **critical goal** and **foundation** of Digital Transformation, rather than a singular end-goal, because it ensures the success and adoption of digital initiatives by building **confidence among stakeholders**
- Without trust, **digital transformation projects risk** failing due to lack of user adoption, reputational damage, and negative financial repercussions.
- Building digital trust **accelerates innovation, improves efficiency, and drives sustainable growth** by fostering reliable and secure digital relationships.

Trust by Design

"Trust at the Heart of Sri Lanka's Digital Future."



Secure by design Vs Digital Trust

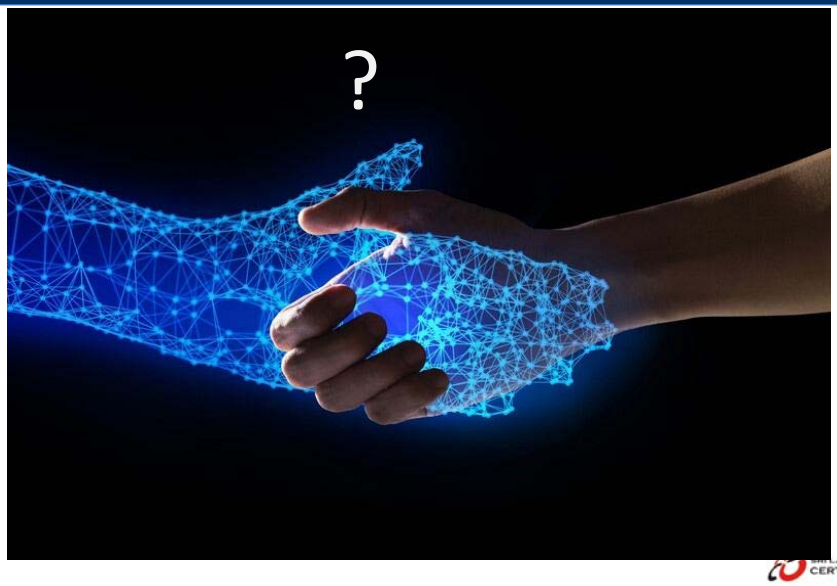
- Digital trust is the broader outcome of these security efforts, combined with transparency and ethical practices, assuring users that their information and interactions are safe and reliable within the digital world.
- Digital Trust is the Next Wave of Cybersecurity

- Secure by **design is a foundational approach** for achieving digital trust, as integrating security into the development process inherently reduces vulnerabilities and builds confidence in a system's reliability, safety, and data protection.

Digital Trust in Intelligent Age

- The more intelligent we make our technology, the more we have to do to earn trust.
- The **World Economic Forum #Digital Trust** Framework gives a concrete way to build more trustworthy technology.

- Our efforts to earn trust must be concrete and effective, while our views on what is trustworthy needs to evolve with people's expectations.



•Societal Trust = ethics, fairness, accountability (human and societal expectations).

WEF -Earning Digital Trust Framework



What Does it Means to you?

- **Mechanical Trust = systems, processes, safeguards (technology reliability).**
- **Societal Trust = ethics, fairness, accountability (human and societal expectations).**



Digital trust is the promise "that digital technologies and services – and the organizations providing them – will protect all stakeholders' interests and uphold societal expectations and values." – The World Economic Forum's Earning Digital Trust report

WORLD ECONOMIC FORUM

- It encompasses the confidence individuals have in the security and reliability of digital environments, including the responsible handling of **personal data and transparent operations.**
- Essentially, it's about building and maintaining confidence in the digital world.

The Role of Digital Trust in Achieving Transformation

- **It's a Prerequisite, Not Just a Byproduct:** While transformation involves technology, trust is a necessary element to make that technology effective and widely adopted.
- **Drives Transformation:** The pursuit of digital trust itself can drive digital transformation by forcing organizations to improve security, transparency, and reliability in their digital offerings.
- **Foundation for Future Success:** As digital technologies advance, particularly AI, the ability to foster and maintain digital trust will become even more critical for future innovation and economic opportunities.

DIGITAL TRUST

is more than an outcome; it is a foundational and strategic imperative that enables the successful and sustainable achievement of digital transformation goals.



Why Digital Trust is Crucial for Digital Transformation

- **Stakeholder Confidence:** Trust is essential for employees, customers, and partners to embrace new digital tools and strategies.
- **Enhanced Security and Privacy:** A focus on digital trust compels organizations to prioritize data security and privacy, which is vital in the digital age.
- **Sustainable Growth and Innovation:** Trusted organizations are better positioned for long-term success and growth, creating environments where innovation can thrive.
- **Risk Mitigation:** Digital trust helps organizations avoid significant financial and reputational damage from data breaches or other digital failures.
- **Competitive Advantage:** Building a reputation for digital trustworthiness can be a key differentiator in the market, leading to increased Citizens loyalty.
- **Drives Transformation:** The pursuit of digital trust itself can drive digital transformation by forcing organizations to improve security, transparency, and reliability in their digital offerings.
- **Foundation for Future Success:** As digital technologies advance, particularly AI, the ability to foster and maintain digital trust will become even more critical for future innovation and economic opportunities.

Digital trust is a “Journey"

DT is an ongoing, evolutionary process of building and maintaining confidence in a digital environment, rather than a destination.

Continuous journey involves adapting to evolving technology and threats by strengthening security, privacy, and transparency, and embedding these **principles across people, processes, and technology to foster reliable and safe digital interactions**



Threats to Digital Trust

The Problem of Cybersecurity

- All Systems that handle sensitive data are attractive targets for cyberattacks, and data breaches **can cause severe damage.**
- Release of low **Quality software** to the market and pass the bug to the customers!
- **Lack of accountability** of the public sector! **Government Cloud Outage, Ransomware Attacks on State Agencies**
- **Increasing Risks to digital trusts- increasingly sophisticated cyber threats**, **data breaches**, **privacy violations**, **complex regulatory environments**, the **rapid pace of technological change**, **supply chain vulnerabilities**, and **emerging technologies like AI**

- However, many risks can be reduced if **security is built into system design and operations from the start.**
- ese risks can lead to **financial losses**, **reputational damage**, loss of **customer loyalty**, and **legal consequences** for organizations.

Risk to Cybersecurity





Erode the public trust
Discredit the Goveranment



Water Board SMS Portal Hacked, Customers Receive Threat Messages

DONT BLAME US,BLAME UR GOV.YOUR WATERBOARD ACCOUNT HAS BEEN HACKED BY ALPHA TEAM.YOUR DATA CAN RECOVER IF WE GOT 1.5BTC TO THIS ADDRESS
1A4vrZAcgWbmxF58AhJ3XVhX4FhqTWtQiF

Risk to Cybersecurity

NEWS

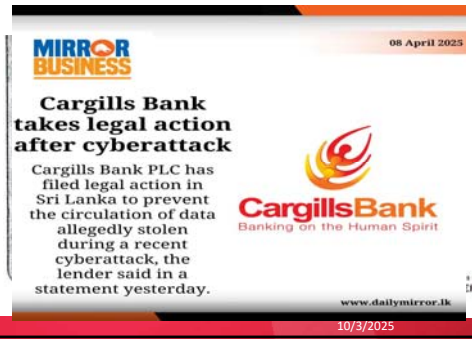
Over Rs.06 bn. siphoned from Commercial Bank accounts!

Published 2 days ago on September 4, 2025
By editor

How Cargill's Bank lost 1.9TB of customer and staff data

Ransomware resilience should be designed into systems before deployment — not bolted on later. By **embedding security obligations into procurement**, governments can **shift the balance of cybersecurity from reactive defense to proactive supplier accountability**.





Digital Trust as Value Co-Creation

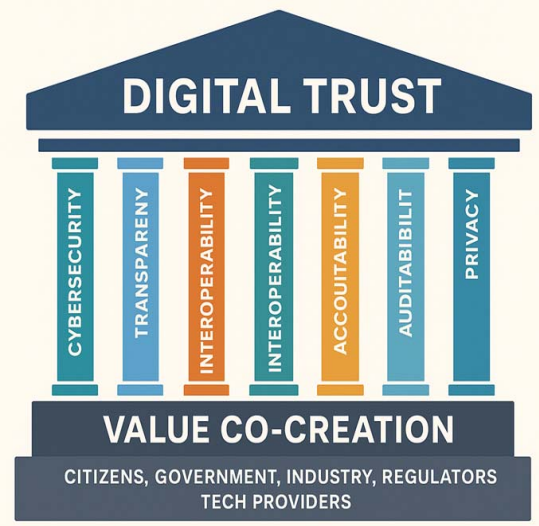
Digital Trust as Value Co-Creation

- **Dimensions of Value Co-Creation in Digital Trust**
  - **Transparency** – Open communication about policies, risks, and accountability builds mutual confidence.
  - **Participation** – Citizens and businesses are active contributors in shaping digital governance and feedback loops.
  - **Shared Responsibility** – Trust is earned collectively through secure by design products, responsible data use, and ethical practices.
  - **Interoperability & Standards** – Common frameworks (NIST, ISO, MOSIP, ID4D principles) enable consistent trust across services.
  - **Continuous Assurance** – Ongoing risk monitoring, certifications, and independent validation reinforce trustworthiness.

Digital Trust Foundation of Value Co-Creation

- Trust (roof)
- 8 WEF pillars (columns)
- Value Co-Creation (foundation base).

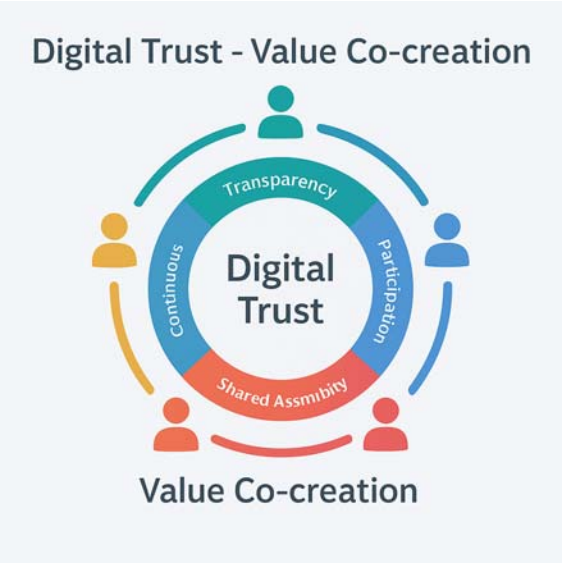
- Trust builds collaboration
- Collaboration co-creates more value
- Co-creation engages all stakeholders



Digital Trust as the Core Value

- Trust is not just a **byproduct of security or compliance** — it is a *tangible value* that enables adoption, confidence, and resilience in digital services.
- Without trust, digital transformation cannot deliver its intended benefits.

- **Outcome of Value Co-Creation:** Co-created trust strengthens confidence in **government digital services**, accelerates adoption of **digital public infrastructure (DPI)**, and establishes a **resilient digital economy**.



Why Co-Creation Matters

- Digital trust **cannot be imposed by one party** (e.g., government or regulators).
- It must be *co-created* **through collaboration** between multiple stakeholders: government, private sector, regulators, technology providers, and citizens.
- Each contributes and benefits from the shared trust ecosystem including government Procurement Offices



Surrounding Elements (Value Co-Creation Drivers)

- **Collaboration** – shared responsibility between government, industry, citizens.
- **Innovation** – trusted environment encourages new digital services, fintech, AI, blockchain.
- **Resilience** – strong trust enables recovery and continuity in crises.
- **Efficiency** – smoother transactions, reduced compliance friction, reliable operations.
- **User Empowerment** – trust enhances adoption, confidence, and digital inclusion.

Secure By Design Concepts

Secure By Design Concepts

1 is a business level goal — it's a *strategic business objective* essential to trust, reputation, and resilience.

2 stated before design kick-off — must be defined at the **very beginning of a project** (requirements procurement)

3 requires real tradeoffs — Balancing cost, usability, and performance.

4 can't be added later — Security isn't a "bolt-on."



SECURE-BY-DESIGN PRINCIPLES

"Procurement officers act as the guardians of digital trust."

Foundational Design	Access & Trust	Lifecycle & Operations	Assurance & Oversight	Development & Testing
• Security as Default • Built-in. Not Bolted On • Shift from Traditional Procurement • Privacy by Design • Secure by Procurement	• Zero Trust Mindset • Least Privilege & Resilience	• Lifecycle Security • Configuration & Patch Management • Continuous Monitoring & improvement • Incident Preparedness & Recovery	• Defense-in-Depth • Vendor Transparency & Accountability • Secure Supply Chain • Accountablity & Auditability	• Threat Modeling & Risk Assessment • Secure Coding Practices • Security Testing & Valldation • Human-Centric Design (Usable Security)

National Digital Trust Framework Blueprint (NDTF-F) v1.0

Inclusion

Citizens | Businesses | Government | Tourists | Startups & Developers

Digital Ecosystem

Digital Trust & Governance

Digital Public Infrastructure
- Payments & Fintech
- SLUDI
- Verifiable Credentials
- National Data Exchange

Governance

Digital Infrastructure
- LGC
- LGN
- Cloud

Digital Services
- Industry 4.0
- E-Government
- E-Commerce

Smart Infrastructure
- 5G
- IoT
- AI

Digital Trust & Governance
- Security & Resilience
- Privacy & Data Protection
- Reliability & Service Continuity
- Transparency & Explamability
- Accountability & Governance
- Ethical AI & Emerging Tech

Governance
- NDTF
- DTCB
- SLCERT / CSA
- Sector Councils

Policy, Legislarion & Institution

Digital Trust by Secure by Design

Secure by Design In Sri Lankan Context

Secure by Design must not only be a **technical standard**, but also a **governance principle** woven into law, data protection, digital infrastructure, and procurement processes—making security **a prerequisite, not an afterthought**



Cybersecurity Bill (forthcoming)

Will legally mandate security integration in systems, services, and critical infrastructure.

Position Secure by Design as the compliance baseline for all digital services, ensuring resillence, accountability, and enforceable govern-



Data Protection Act requirements

Embeds privacy and security safeguards in the design of data collection, processing, and storage,

Frame Secure by Design as Privacy by Design + Security by Design, ensuring minimal data colle-ction, encryption by default, and lawful processing.



Digital Economy Blueprint: DPI, SLUDI, MOSIP

National-scale digital platforms (Digital Public Infrastructure, Unified Digital ID. MOSIP-based frameworks) must be trus-tworthy, interoperable, and secure.

Highlight Secure by Design as critical for scalable, interoperable, and citizen-trust -centered digital ser-



Procurement offlcers as gatekeepers of trust

Procurement determines whether acquired technology follows Secure by Design principles.

Make procurement frameworks mandate security assurance, certification, vendor due diligence, and lifecycle risk assessments, turning officers into frol

Global Best Practices & Standards

- **United States**
  - **CISA Secure-by-Design Pledge** – vendor guidance on building security in from the outset.
  - **NIST Cybersecurity Framework (CSF 2.0)** & **NIST SP 800-161** – supply chain and critical infrastructure risk management.
- **European Union**
  - **NIS2 Directive** – mandates stronger supply chain cybersecurity obligations.
  - **EU Cybersecurity Act** – certification framework for ICT products and services.
- **United Kingdom**
  - **NCSC Procurement Guidelines** – integrating security requirements into procurement processes.
- **International Standards**
  - **IISO 27001 ISMS / ISO/IEC 27036** – security in supplier relationships and procurement.
- **Asia-Pacific Example**
  - **Singapore GovTech Model** – embedding “security-by-design” into government ICT procurement.

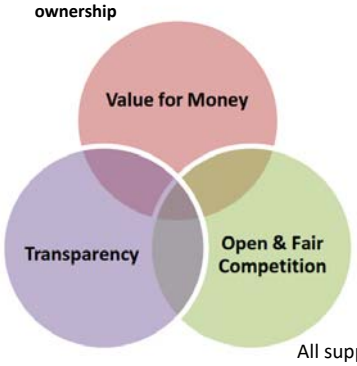
Global Best Practices & Standards

- **Key Lessons for Sri Lanka**
  - Security requirements must be **mandated in procurement**, not left optional.
  - Global standards provide **benchmarks for compliance** (Cybersecurity Bill, Data Protection Law).
  - Adapt best practices to local context: **cost-effective, transparent, and enforceable** procurement frameworks

Changing Rules of Government Procurement

Rules of Government Procurement

- Focus is on achieving **the optimal balance** between cost, quality, risk, timeliness, and reliability. Evaluation is based on **total cost of ownership**



Procurement requirements, procedures, and evaluation criteria are openly published

NATIONAL PROCUREMENT COMMISSION OF SRI LANKA

ICTA Guide :
All about general bid governance

All suppliers are treated equally and fairly.
All suppliers receive the same information, ensuring a **level playing field.**

- **Myth Buster**
  "Lowest Quote Always Wins?" – Not True!
- Infor system procumbent template- National Procumbent commission
- Contracts are not awarded solely on the lowest price !
- Government agencies should consider security quality, reliability, and risk factors in addition to cost.
- Suppliers should avoid undercutting prices at the expense of essential criteria like service quality and delivery assurance.

Rules of Gov. Procurement in Earning Digital Trust

1	2	3	4	5	6	7	8	9	10
Open and fair Competitio	Transparency	Value for Money	Security by Design	Accountabi-lify & Auditability	Inclusive-ness & Accessibility	Compii-with an Standa-ards & Reguiations	Ethics & Respons: ble AI	Sutanabili ty and Long term Viability	Citizen Centric Outcomes
All suppliers are treated equally and fairly. Same info. shared with all bidders to ensure a level playing field. Competitive environment motivates suppliers to provide their best proposals.	Procurement requirements procedures, and evaluation criteria are openly published (e.g., e-Gov portals). Suppliers clearly understand the agency's needs and assessment process.	Balance between cost, quality, risk, timeliness, and reliability. Evaluation considers total cost of ownership, not just initial price.	Cybersecurity and data pro-rection built into pro-curemment requirements Ennsres as integrity and public trust through oversight	Decisions and processes are documented and independent ly auditable. Reinforces integrity and public trust through oversight.	Open opportunities for SMEE, local innovators and under-representted groups Reduces over reliance on large or foreign vendors	Vendors mus comply with national cybersecurity, data protection, and interoperabili y standards (e.g., ISO, NIST, ID4D, MOSIP).	For emerging tech (AI, biometrics, blockchain), ensure ethical use, bias reduction, and privacy safeguards.	Consider environmen tal sustainabilit y, scalability, and long-term support.	Success measured by citizen trust, service quality, Fecuse on building confidence in digital public infrastruc-ture

Current Challenges in Public Sector IT Procurement

Current Challenges in Public Sector IT Procurement

Sections

Thu, 02 Oct 2025

E-PAPER | TODAY'S PAPER | AUSTRALIAN EDITION

Truth hurts. We report it.
DAILY MIRROR ONLINE
DAILYMIRROR.LK

Home Latest News Opinion Features Expose Business Sports World News Videos The Sun Life Obituaries

Trending Breaking News Top Stories

Sri Lanka's annual loss due to government tender corruption amounts to 1% of Gross Domestic Product: Verité Research

Current Challenges in Public Sector IT Procurement

Procurement Process Issues

- Lowest-cost bidding undermines security
- Long procurement cycles → outdated technology

Vendor-Related Risks

- Limited vendor accountability for vulnerabilities
- Weak vendor security requirements

Security Gaps in Procurement

- Lack of standardized security requirements in RFPs
- Default configurations & limited assurance
- Lack of lifecycle security management

Governance & Oversight Weaknesses

- Inadequate monitoring & compliance checks

There is often **no independent verification** or guarantee that the vendor's configurations, patches, or controls meet the required security standards.

Shifting the Balance of Cybersecurity

Shifting the Balance of Cybersecurity

- The goal is to move the burden of cybersecurity from the end user to the manufacturer, ensuring that systems and products are resilient and trustworthy from the start**.**

- **Key Message:**
  Cybersecurity requires a **shift in priorities** — from focusing primarily on **cost, speed, and convenience** to ensuring **security, trust, and resilience** as foundational elements.
- ***This shift is essential for building trustworthy and sustainable digital infrastructure***.

Shifting the Balance of Cybersecurity



Why Procurement Matters for Cybersecurity

- **Rising Cyber Threats**: Governments are prime targets; weak procurement choices lead to vulnerable systems and insecure software.
- **Security by Design**: Embedding cybersecurity requirements in procurement is far cheaper and safer than post-deployment fixes.
- **Protection of Citizen Data**: Public sector systems manage sensitive personal and national data—breaches risk financial loss, reputational harm, and national security.
- **Public Trust at Stake**: Citizens expect government services to be secure and reliable; procurement failures undermine confidence.
- **Regulatory & Compliance Demands**: Alignment with Sri Lanka's Cybersecurity Bill, Data Protection Law, ISO/IEC 27001, and NIST CSF 2.0 is mandatory.
- **Strategic Role of Procurement**: Every IT purchasing decision directly shapes government cyber resilience and the ability to safeguard digital infrastructure.
- **Procumbent officer Stand as the Trust Anchors in Procurement**

What is a Request for Information (RFI)?

- The RFI is a method used for market research and pre-tender engagement. It allows government agencies to gather written information about market capabilities and practices.
- While RFI responses are **not binding offers** and cannot directly lead to contract awards, they help agencies understand suppliers' capabilities and solutions.
- The insights gained may also guide the formulation of requirements for future Tenders and Quotations.

What is a Request for Proposal(RFP)

- An RFP is a formal document issued by government agencies or organizations to invite suppliers or service providers to submit detailed proposals for delivering a specific product or service.
- Unlike an RFI, which is **exploratory, an RFP sets out clear requirements, scope of work, evaluation criteria, and contract terms**.
- Suppliers responding to an RFP **must provide a comprehensive proposal, including technical solutions, timelines, and pricing**. The agency then evaluates these proposals to select the most suitable vendor.
- **The Major tool in designing Secure by design in to procurement**

Shifts Cybersecurity Responsibility

Shifts cybersecurity Responsibility away from end-users



Source : Cybersecurity and Infrastructure Security Agency (CISA)

U.S. CISA's Secure by Design Guidance

- Initially published in April 2023, the Cybersecurity and Infrastructure Security Agency (CISA) **"Secure by Design" Guidance** is a voluntary framework for software manufacturers. It aims to strengthen the security of technology products while shifting cybersecurity responsibility away from end-users.
- **"Secure by Design"** means that technology products are developed with security as a **fundamental principle**, **ensuring reasonable protection against malicious actors attempting to compromise devices, data, and connected infrastructure**.
- Products that are ***secure by design*** **are created, shipped, and maintained with security integrated from the earliest stages** of the software development lifecycle—making security a core design consideration rather than an afterthought.

U.S. CISA's Secure by Design Framework

- This guidance is a counterpart to CISA's Secure by Design guidance for technology manufacturers, which lays out three secure by design principles:
  - Take ownership of customer security outcomes,
  - Embrace radical transparency and accountability, and
  - Build organizational structure and leadership to achieve these goals.
- This guide bridges that gap by offering resources organizations can leverage to assess product security maturity and whether a manufacturer follows secure by design principles.

U.S. CISA's Secure by Design Guidance

- Organizations can integrate product security considerations into various stages of the procurement lifecycle:
  - **Before procurement,** by posing questions to understand each candidate software manufacturer's approach to product security.
  - **During procurement,** by integrating product security requirements into contract language, as appropriate.
  - **Following procurement,** by continually assessing software manufacturers' product security and security outcomes.

The 7 Goals of the Secure by Design Pledge

1. **Increase Multi-Factor Authentication (MFA) Adoption** – ensure widespread integration of MFA across products.
2. **Eliminate Default Passwords** – reduce or eliminate use of vendor-supplied default credentials.
3. **Reduce Entire Classes of Vulnerabilities** – proactively address systemic weaknesses (e.g., memory safety issues).
4. **Improve Patch Adoption** – increase the speed and ease of customer installation of security patches.
5. **Publish a Vulnerability Disclosure Policy (VDP)** – enable coordinated reporting of flaws by researchers.
6. **Increase Transparency in Vulnerability Reporting** – publish timely CVEs for critical vulnerabilities.
7. **Enhance Customer Intrusion Detection** – increase customers' ability to collect logs and evidence of compromise.

Mapping: CISA Secure by Design Goals ↔ Sri Lanka Frameworks

CISA Secure by Design Goal	Cybersecurity Bill (Sri Lanka)	Personal DPA Lanka)	Relevance for Sri Lanka
1. Increase MFA adoption	Supports Bill's mandate for baseline security controls across critical information infrastructure (CII).	Enhances safeguards for access to personal data systems, reducing unauthorized access risks.	Encourages government-wide MFA adoption for CII and citizen-facing portals (e.g., SLUDI, eGov services).
2. Eliminate default passwords	Aligns with Bill's emphasis on secure system configurations and incident prevention.	Prevents weak authentication from exposing personal data.	Should be mandated in public sector procurement guidelines and enforced in system audits.
3. Reduce entire classes of vulnerabilities	Supports Bill's focus on risk-based cybersecurity management and security by design.	Limits systemic flaws that could lead to large-scale data breaches.	National coding standards and secure development practices should be promoted via SLCERT/CSA.
4. Improve patch adoption	Bill requires timely vulnerability management and CERT-led incident coordination.	Delays in patching may lead to data exposure, violating PDPA.	Government ICTA/SLCERT should enforce patch SLAs in vendor contracts.
5. Publish a Vulnerability Disclosure Policy (VDP)	Directly supports Bill's incident reporting and disclosure obligations for public and private sectors.	Transparency on vulnerabilities supports data breach notification duties under PDPA.	Sri Lanka needs a national VDP framework to guide agencies/vendors.
6. Transparency in vulnerability reporting (timely CVEs)	Helps Bill's mandate for cyber incident information sharing and CERT coordination.	Ensures data controllers can take timely action to protect citizens' personal data.	Sri Lanka should adopt CVE reporting standards via SLCERT/NCA.
7. Enhance customer intrusion detection (logging & evidence)	Supports Bill's requirement for continuous monitoring, audit trails, and forensic readiness.	Logs are key for demonstrating accountability and breach response under PDPA.	Should be enforced as a compliance control in critical systems (banks, telecom, government registries).

SLCERT/CSA could use the pledge goals as a **practical baseline framework** for government and vendor compliance.
Embedding these in **procurement contracts, audit checklists, and SLUDI/DPI governance** will operationalize "secure by design" for Sri Lanka.

Integrating Security in Procurement Lifecycle

Integrating Security in Procurement Lifecycle

1. Pre-tender – Define security requirements
2. Tender evaluation – Assess vendor security posture
3. Contracting – Include SLA/KPI for security
4. Delivery & operation – Monitor compliance
5. End-of-life – Secure decommissioning

Integrating Security in Procurement Lifecycle -1

1. Pre-Procurement

- Define baseline **minimum security standards**
- Establish **RFP security requirements**, SLAs, and evaluation criteria

2. RFP / Tender Stage

- Include **security certifications** (e.g., ISO 27001, SOC 2)
- Specify compliance obligations (e.g., data protection law, NIST/ISO controls)

3. Evaluation & Vendor Selection

- Apply **security scoring & risk ratings**
- Assess **vendor security maturity** (governance, incident history, resilience)
- Validate certifications and references

Integrating Security in Procurement Lifecycle -2

4. Contracting Stage

- Insert binding **security clauses**:
  - Vulnerability Disclosure Policy (VDP)
  - Patch & vulnerability management
  - Incident reporting & response obligations
  - Compliance audit rights

5. Post-Contract / Operations

- Enforce **continuous monitoring & compliance checks**
- Periodic audits and security reviews
- Ongoing incident reporting & risk reassessment

Principles for Procurement Staff

Government procurement teams can shift to a "Secure by Design" mindset by adopting **following principles:**



- **Create clear accountability**.
  - Ensure contracts with suppliers explicitly detail cybersecurity requirements and a shared accountability for risk management.
- **Prioritize a security culture**.
  - Treat cybersecurity as a business and delivery risk, not just a technical or compliance issue. This encourages buy-in from senior leadership and project teams.
- **Embrace continuous risk management**.
  - Move beyond one-time assessments. Procurement should embed regular security reviews and risk mitigation strategies throughout the entire product lifecycle, not just at the time of purchase.
- **Source secure technology products.**
  - Conduct security due diligence on third-party products, assessing their built-in security features before purchase. Mitigate any identified risks to an acceptable level.

Principles for Procurement staff-2

- **Demand secure defaults**. Specify that products must come with secure configurations enabled out-of-the-box, such as strong multi-factor authentication (MFA) for privileged users.
- **Incorporate secure coding practices**. Look for vendors who demonstrate a commitment to secure development practices, use memory-safe programming languages, and test for vulnerabilities throughout their development lifecycle.
- **Insist on transparency**. Choose suppliers who embrace radical transparency. This includes providing a detailed Software Bill of Materials (SBOM) and having clear vulnerability disclosure programs.
- **Design for resilience.** Require vendors to use a defense-in-depth approach with multiple layers of security. This ensures a system can withstand an attack even if a single control fails.

Procurement strategies and tactics-

Procurement strategies and tactics-1

To implement Secure by Design, procurement staff should adapt their process with the following strategies:

1. **Review and update procurement documents.** Embed Secure by Design principles and requirements directly into Requests for Proposals (RFPs), contracts, and supplier evaluation criteria.
2. **Conduct security reviews and threat modeling**. Integrate security reviews and threat modeling into the due diligence process for new products or services. This helps identify and prioritize risks based on the specific use case.
3. **Collaborate with security teams**. Establish a working group with cybersecurity experts to ensure the right security controls are included in procurement decisions.



Procurement Strategies and Tactics-2

4. **Use vendor pledges as a guide**. For enterprise software, ask potential vendors if they have signed initiatives like the U.S. Cybersecurity and Infrastructure Security Agency's (CISA) Secure by Design Pledge. This can serve as a starting point for assessing their commitment to secure practices.
5. **Prioritize capability over accreditation**. Instead of focusing on a singular accreditation stamp, evaluate a vendor's ongoing security practices and ability to manage risk throughout a product's lifecycle.
6. **Invest in internal training**. Procurement and IT staff need to be trained on security best practices to effectively evaluate and manage risks associated with new technologies



The old vs. the new procurement model

Feature	Old model (Reactive, Compliance-Focused)	New model (Secure by Design)
Security focus	Testing and patching vulnerabilities after a product is built and purchased.	Building security in from the very beginning of the design and procurement process.
Burden of responsibility	Largely on the government agency (the customer) to find and fix security issues.	Shared responsibility, with manufacturers and suppliers taking greater ownership of their products' security outcomes.
Risk management	A one-time or periodic activity to achieve accreditation.	Continuous risk management throughout the entire product lifecycle.
Security as a feature	Treated as an add-on, with secure configurations often costing extra.	Security is a core, built-in feature, enabled by default at no additional cost.

Secure Procurement

- **Example:** GovTech Singapore & Estonia e-Gov Model
- **Early Security Integration**
  - Embedding security requirements in RFPs, vendor evaluation, and contracts.
  - Security testing, certifications, and compliance checks before deployment.
- **Reduced Procurement Risks**
  - Minimizes vendor lock-in and legacy vulnerabilities.
  - Ensures compliance with data protection & cybersecurity regulations.
  - **Builds trust in public services and digital platforms.**
- **Adaptation for Sri Lanka**
  - Align procurement frameworks with the forthcoming **Cybersecurity Bill** and **Data Protection Act**.
  - Require vendors to comply with **ISO 27001, NIST CSF, and MOSIP security guidelines**.
  - Establish a **National Secure Procurement Policy** for all government ICT projects.
  - Train procurement officers as **gatekeepers of digital trust**.

Case Studies failed government procurements

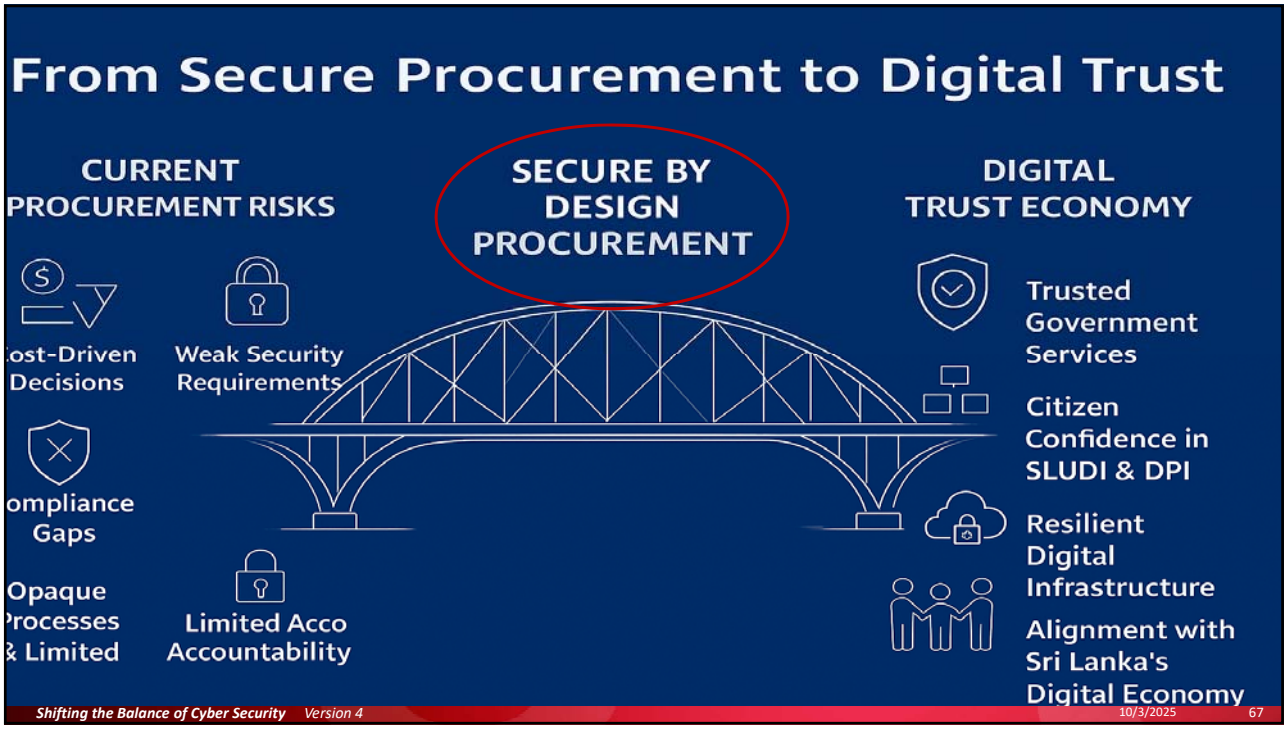
Global Case Studies of Procurement Failures

When Procurement Fails: Lessons from Around the World

- **Visual Idea:** Icons for each case (hospital, government building, ID card, census website)
- **UK NHS (2017 – WannaCry):** Outdated Windows XP, no patching → Hospitals crippled.
  - **Lesson:** Procurement and maintenance contracts must ensure **timely patching, upgrades, and vendor support**. Buying software/hardware without lifecycle management creates national-level risks.
- **US OPM (2015):** Weak identity security → 21.5M records stolen.
  - **Lesson:** Procurement of identity systems must enforce **strong authentication, encryption, and continuous monitoring**. Weak identity governance exposes entire governments.
- .

Global Case Studies of Procurement Failures

- **India Aadhaar (2018–20): Third-party app leaks** → Biometric data exposed.
  - **Lesson:** Digital ID procurement must include **strict vendor compliance, API security, and third-party risk management**. Even if the core system is strong, weak links in the ecosystem can compromise national security.
- **Australia online census portal crashed (2016):** DDoS + poor resilience → Website crash.
  - **Lesson:** Procurement of critical digital services must require **scalability, stress-testing, DDoS protection, and resilience**. Governments must contractually enforce performance under peak demand



Practical Secure by Procurement Framework

Secure Procurement Framework Benefits

- Reduces **procurement risks** (vendor lock-in, insecure solutions).
- Ensures compliance with **Cybersecurity Bill, Data Protection Act, Digital Economy Blueprint**.
- Builds **trust in government digital services** (SLUDI, DPI, National Data Exchange).
- Makes procurement officers the **first line of defense in cybersecurity governance**.

Practical Secure by Design Strategies

- Vendor Security certifications (ISO 27001, SOC 2)
- Vulnerability disclosure policies
- Patch/update timelines (Critical <14 days)
- Independent security testing before acceptance
- Continuous monitoring & risk reviews

- How do you design " Secure by Design"?

Secure Procurement Checklist (Preview)

- Security requirements in RFP
- Vendor cybersecurity posture evaluated
- Contractual compliance clauses included
- Data protection & privacy clauses
- Incident response & reporting clauses
- Continuous monitoring plan
- Right to audit and penalties

Table 1: Secure Procurement Checklist -23 Questions

Model Secure RFP Clauses

- Vendor must comply with ISO 27001 / SOC2 / CSA STAR
- Vulnerability Disclosure Policy (VDP) required
- Mandatory patch management & reporting
- Independent security assessments annually
- Integration with National SOC & threat intelligence feeds

Table 2: Secure Procurement Model Closes -23 Questions

Secure Procurement -Avoid Vendor Lock-In

- **Vendor lock-in poses significant risks to government digital transformation projects, including high switching costs, reduced flexibility, and security vulnerabilities.**
- **Secure procurement practices can mitigate these risks by embedding openness, interoperability, and security into every stage of the procurement process.**
- These clauses protect **data sovereignty, interoperability, security independence, and smooth exit** — the four main areas of vendor lock-in risk.

Table 3: Secure Procurement Closes Vendor Locking 8

Implement national certification for IT vendors

- **Scoring & Certification Outcome**
- Each checklist item scored **0–5**
- Weighted by domain:
  - Governance (20%)
  - IAM (15%)
  - Vulnerability/Patching (20%)
  - Incident Response (15%)
  - Secure Development (20%)
  - Certification/Continuous Improvement (10%)
- This integrates **CISA Secure by Design pledge**, **ISO 27001**, **Sri Lanka Data Protection Act**, and **global security standards** into one **Vendor Certification Framework**

Vendor Security Certification Maturity Levels

Level	Label	Assessment Criteria	Global Alignment
Level 1 – Bronze	Baseline Trust	- Compliance with national law (Sri Lanka Data Protection Act) - Basic policies documented - Strong passwords & RBAC - Ad-hoc patching - Basic IR plan	Initial (Ad hoc)
Level 2 – Silver	Regulatory Trust	- ISO 27001 alignment - MFA for admins - Defined patch SLAs - Vulnerability Disclosure Policy (VDP) - Annual IR testing	Managed / Defined
Level 3 – Gold	Assured Trust	- Full CISA Secure by Design pledge compliance - MFA for all users - Public VDP, coordinated disclosure - Secure SDLC & supply chain assurance - External audits (ISO/SOC 2)	Integrated / Risk-based
Level 4 – Platinum	Trusted by Design	- Zero Trust fully implemented - Automated DevSecOps pipeline - Continuous vulnerability monitoring - Independent 3rd-party audits (CSA STAR, SOC 2 Type II) - Real-time transparency dashboards	Optimized / Continuous Improvement

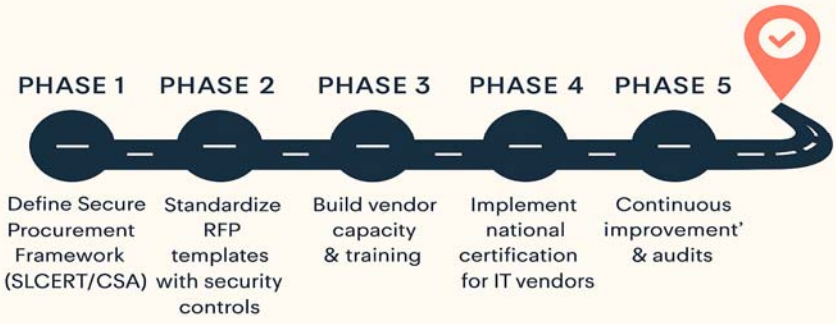
Vendor Security Certification Maturity

Level	Score Range (%)	Description
Bronze	40-59%	Baseline Trust (national law compliance, basic controls)
Silver	60-74%	Regulatory Trust (ISO 27001 alignment, MFA admins, VDP, patch SLAs)
Gold	75-89%	Assured Trust (CISA Secure by Design pledge, secure SDLC, external audits)
Platinum	90%+	Trusted by Design (Zero Trust, DevSecOps, continuous monitoring, 3rd-party audits)

Vendor Security certification Maturity Assessment

ROADMAP

Secure IT Procurement for Sri Lanka



By Treasury

Key Takeaways – Secure by Design Procurement

- **Digital trust starts with secure procurement** — every procurement decision shapes the nation's cybersecurity posture.
- **Procurement officers are the gatekeepers of resilience and compliance**, enabling trust across government and citizens.
- **Secure by Design delivers lasting value** — reducing risk, cutting costs, and strengthening digital trust.
- **Shift from "lowest cost" to "best value with security"** — embed security as a business-level requirement, not an afterthought.
- **Vendors must be held accountable** — through security testing, certification, and continuous compliance monitoring.
- **Policy, governance, and culture are critical** — public sector leadership must set the standard for Secure-by-Design adoption.
- **Global lessons show that failures are costly** — proactive secure procurement prevents breaches and builds trust.

Closing & Q&A

